PHOENIX SECURITY

CYBER RISK DEFENDERS CLUB

WEBINAR

ONE BACKLOG AND SECURITY CHAMPIONS

Beyond ASPM, we explore the role of metrics in Security Champion Programs, which are key to enhancing application security. Discover how to unify application and cloud security vulnerabilities into one actionable backlog, and learn the key metrics that drive effective security initiatives.

Dustin Lehr

SECURITY CHAMPION PROGRAM LEADER FOUNDER @ KATILYST

www.phoenix.security.com 20 November

9AM PST / 11 AM CST / 5PM GMT

Agenda – Dustin

Intro

- Intro
- Security Champion what it is and what is for
- When to start a security champion program?

Webinar

- Appsec vs Production security
- One backlog and help of having all the findings in one place
- Metrics that matters
- Prioritization, reachability, attribution

I feel your pain

Alert FATIGUE
No COMMON LANGUAGE
=
BURNOUT

CVE SURGE OUTPACES SECURITY BUDGET GROWTH IN 2023

 # CVE
220 538 **

35% YoY increase

Most Vulnerabilities are Critical - High (58%)**

Only 1-10%

of these is actually relevant *

Only 6%

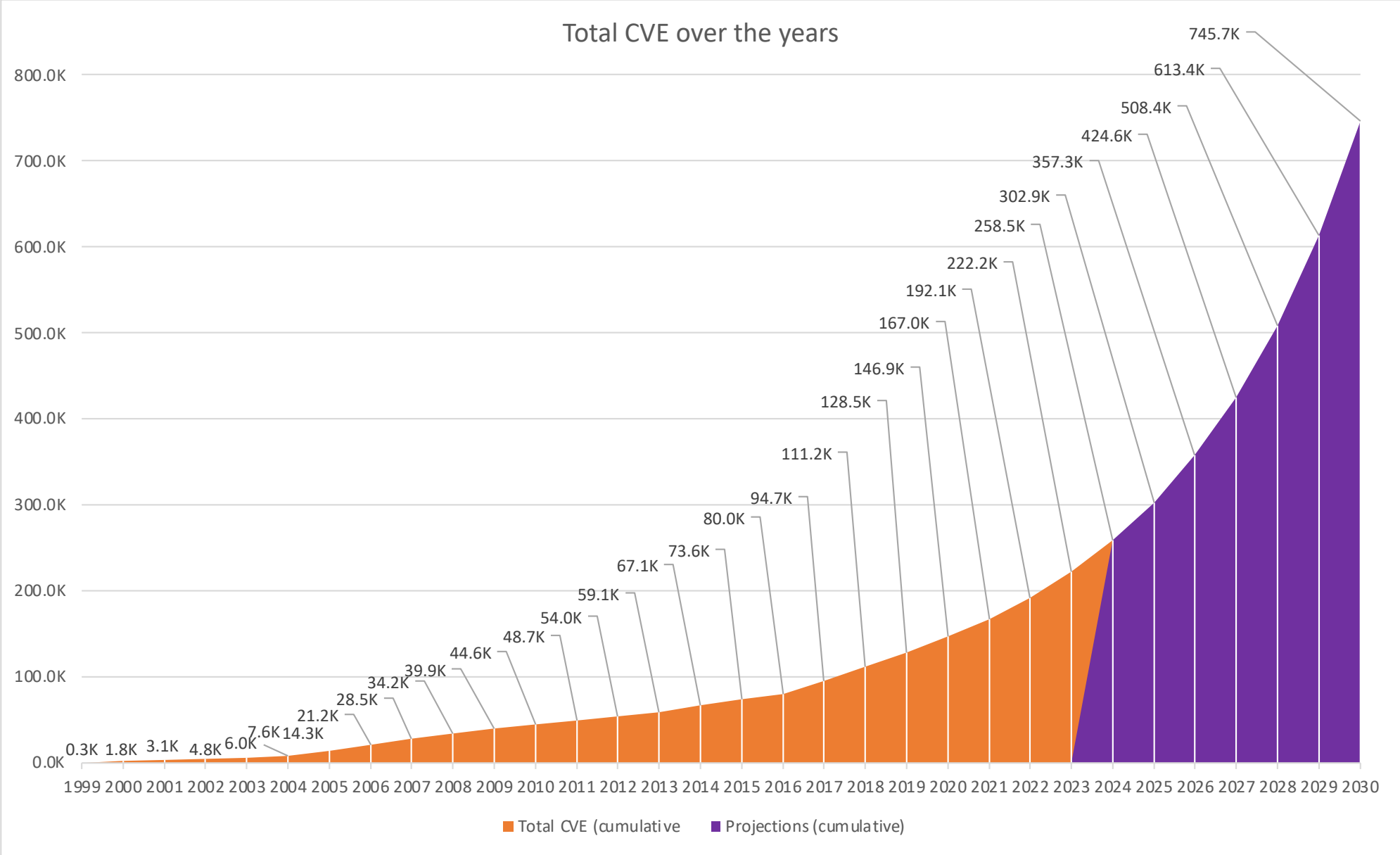
Budget increase for security team down from from 17% ***

*FIST / EPSS

** NVD/CVE STATISTICS

*** UK GOVERNMENT

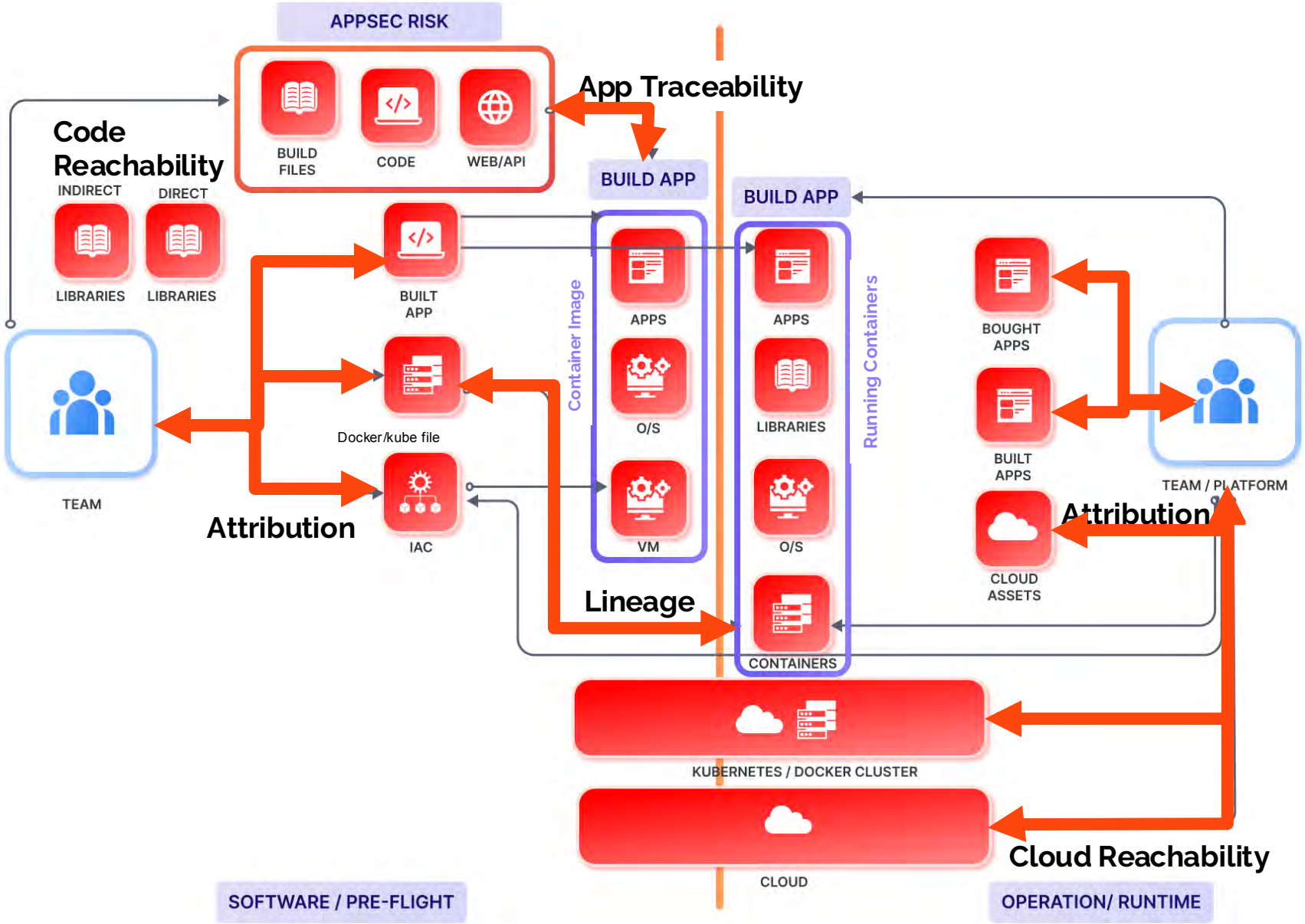
The Race to a Million vulnerabilities...not that far away



Bridging the gaps appsec and environment

Phoenix correlates, contextualizes and deduplicates by linking together assets using 4 dimensions

- Attribution
- Lineage
- Traceability
- Code/Cloud Reachability



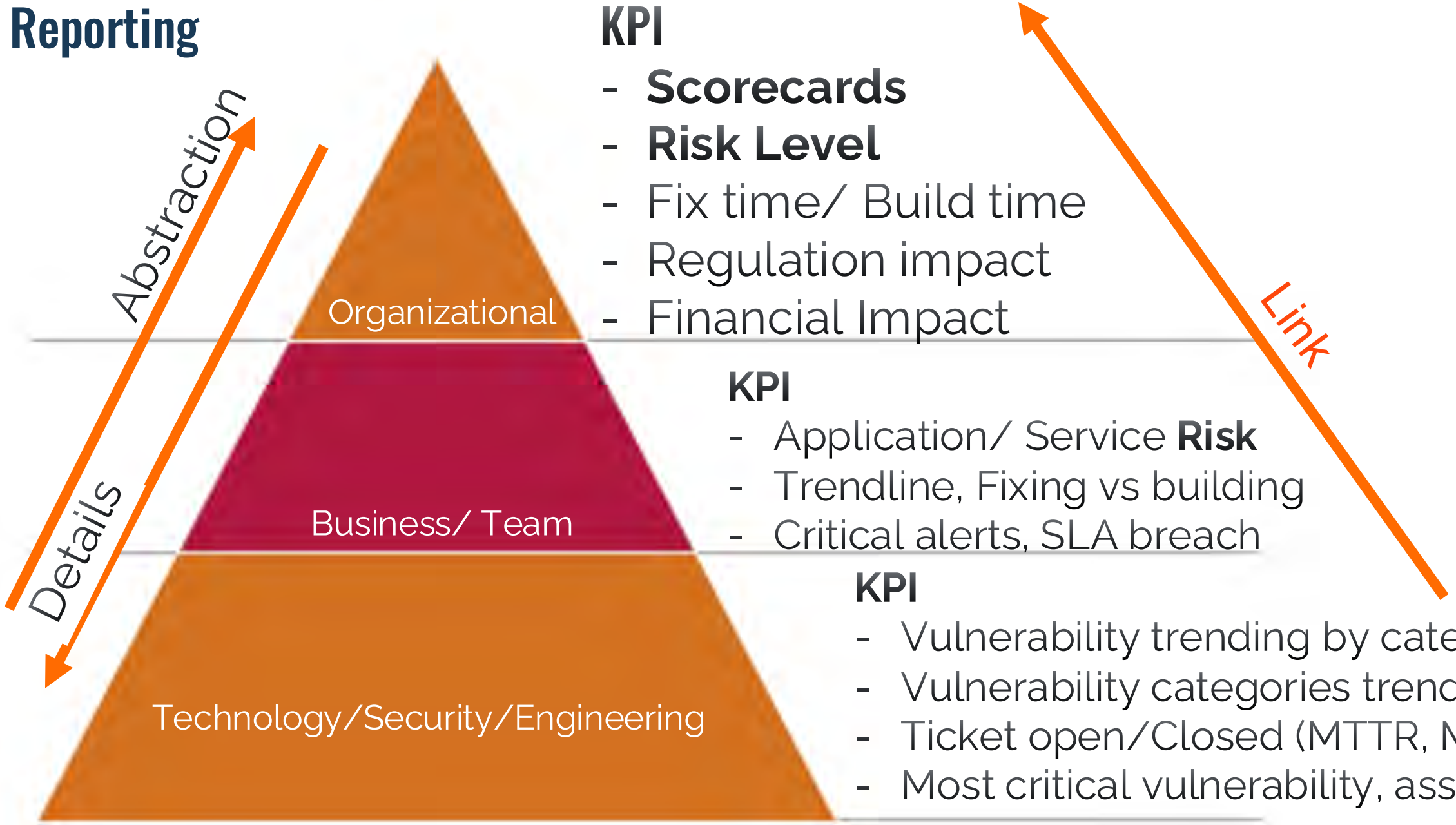
One Backlog and Metrics that matters

Metrics

Metric	Pro	Con
SLA	- Measure a target date - Is a single measure	- Does not account for context - Is flat and will expire as not all the vulnerabilities are fixed
MTTR	- Indication on how fast vulnerabilities are fixed	- If not applied to the "ACTIVE" tickets can be misleading
Risk targets	- More flexible than SLA	- Understanding what risk is and why changes can be complex

- Common challenge – Attributing the right vulnerabilities to the right teas

Reporting



KPI

- **Scorecards**
- **Risk Level**
- Fix time/ Build time
- Regulation impact
- Financial Impact

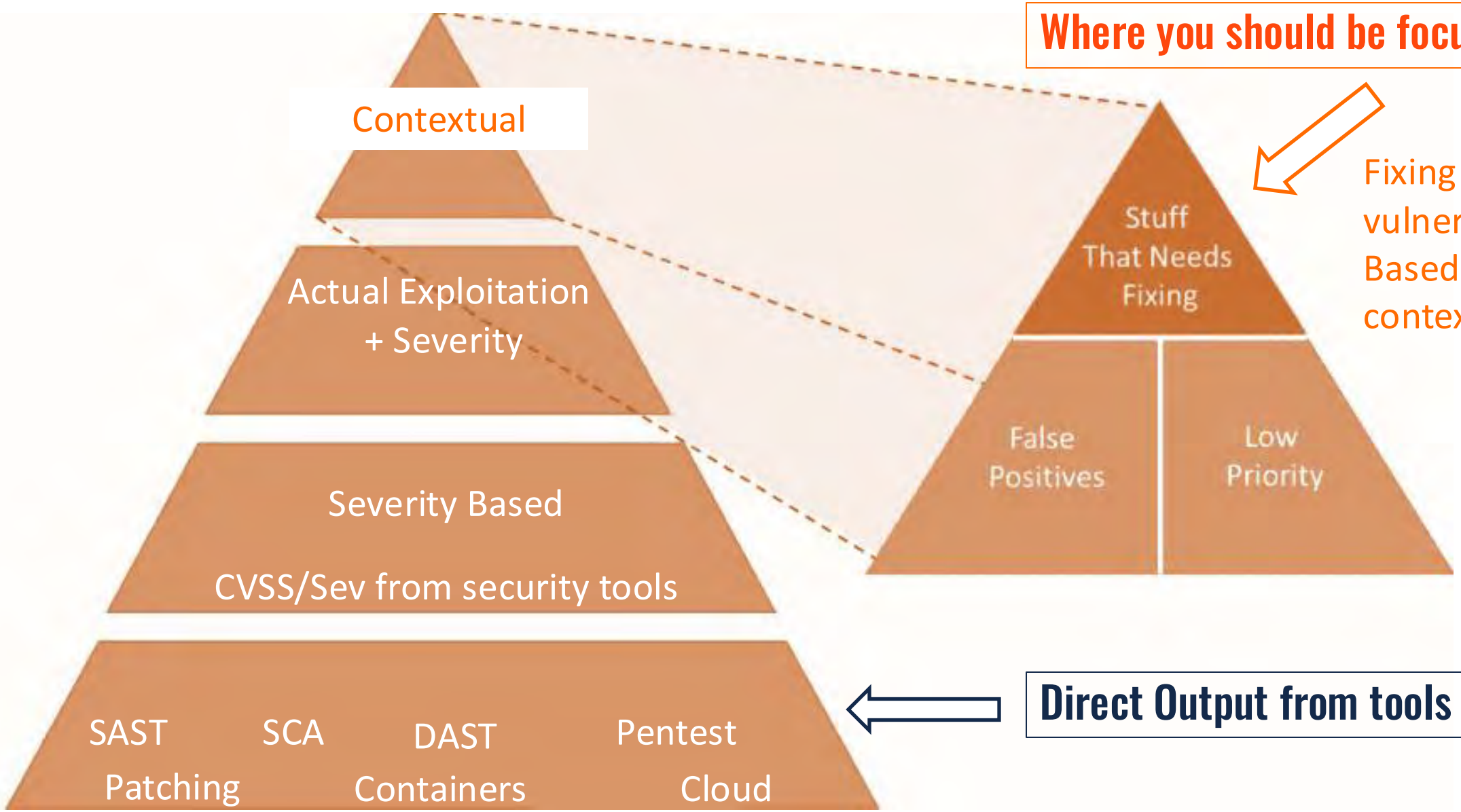
KPI

- Application/ Service **Risk**
- Trendline, Fixing vs building
- Critical alerts, SLA breach

KPI

- Vulnerability trending by categories
- Vulnerability categories trending
- Ticket open/Closed (MTTR, MTTO)
- Most critical vulnerability, assets

Prioritization is so 90....

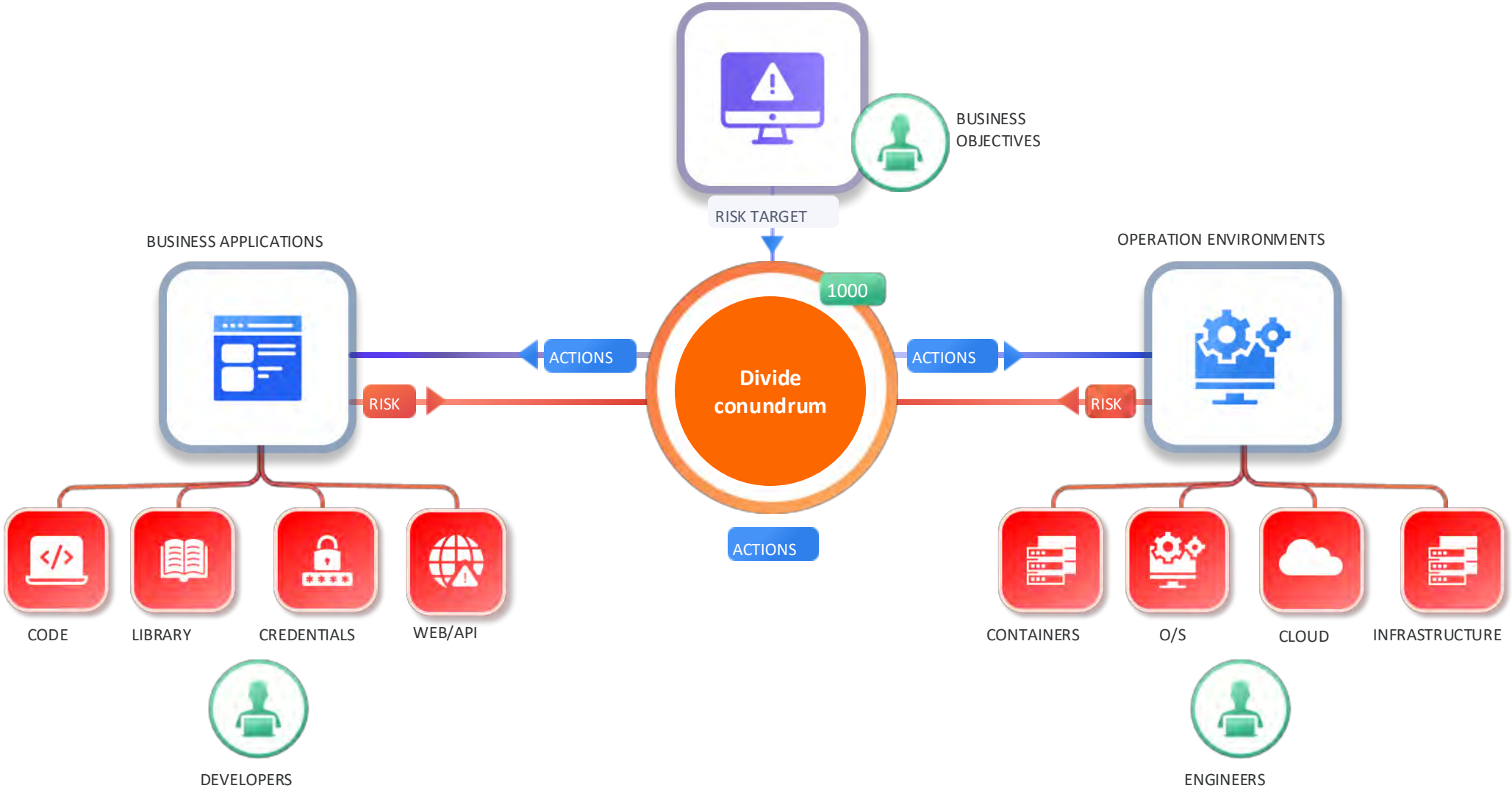


Where you should be focusing

Fixing vulnerabilities Based on contextual risk

Direct Output from tools

From Number of Vulnerabilities to risk objectives
Drive Risk down, Connect left to right



Common Actions

Application Security

CODE

LIBRARY

CREDENTIALS

WEB/API

RISK TARGET

BUSINESS OBJECTIVES

OPERATION ENVIRONMENTS

CLOUD

CONTAINERS

O/S

INFRASTRUCTURE

Risk Magnitude	Team name	Changes	Vulnerabilities resolved	Vulnerabilities introduce	Vulnerabilities breackdown
12k	Core team	21%	492 +27	816 +42	
15k	Product	4%	447 +49	583 +13	
23k	3rd party	10%	561 +60	826 +44	
34k	Marketing	10%	798 +42	426 +92	

DEVELOPERS

ENGINEERS

Common Actions

Application Security

CODE

LIBRARY

CREDENTIALS

WEB/API

DEVELOPERS

RISK TARGET

BUSINESS OBJECTIVES

One Backlog

OPERATION ENVIRONMENTS

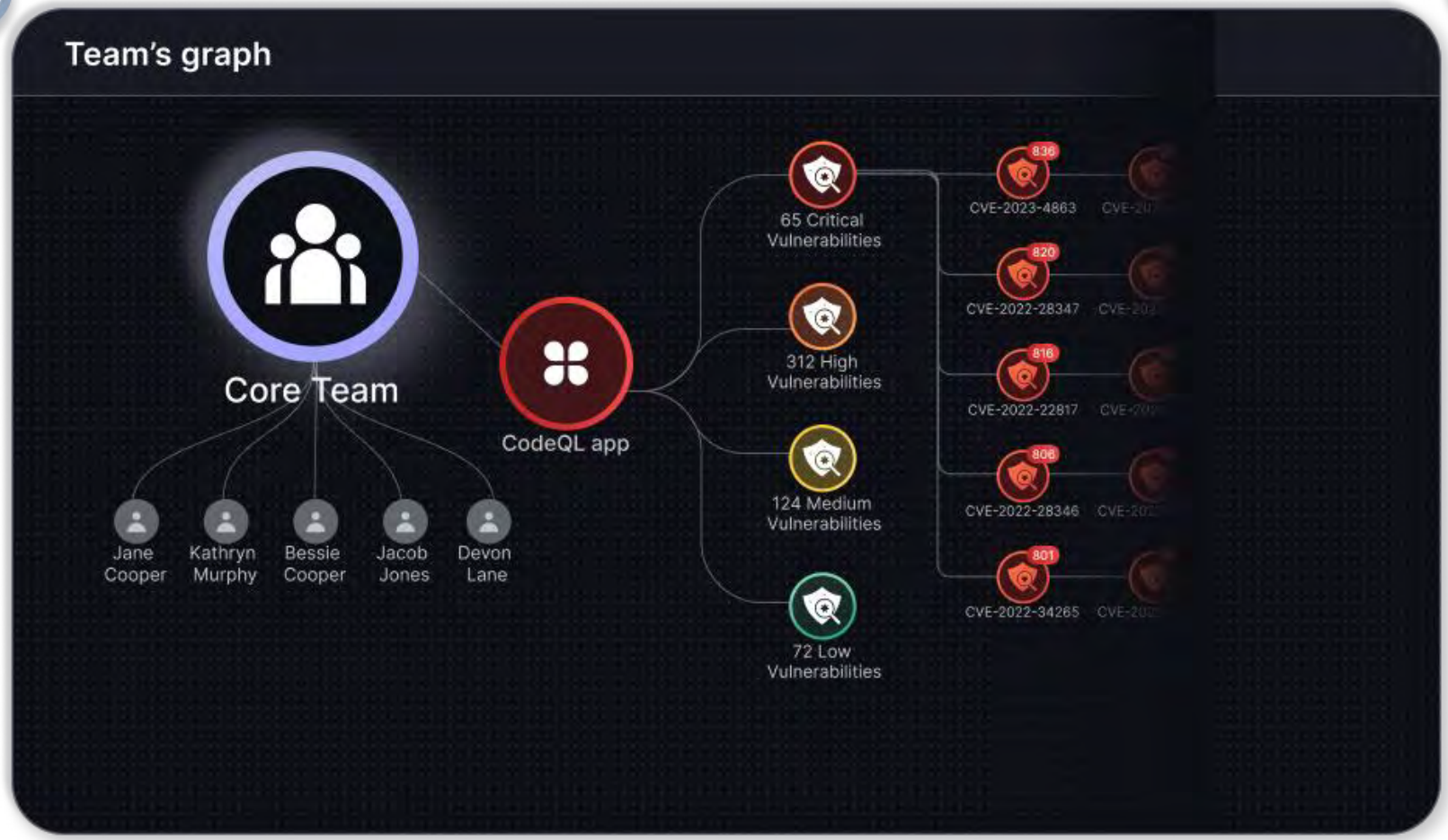
CLOUD

CONTAINERS

O/S

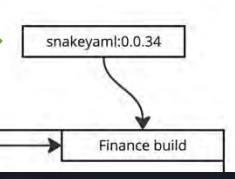
INFRASTRUCTURE

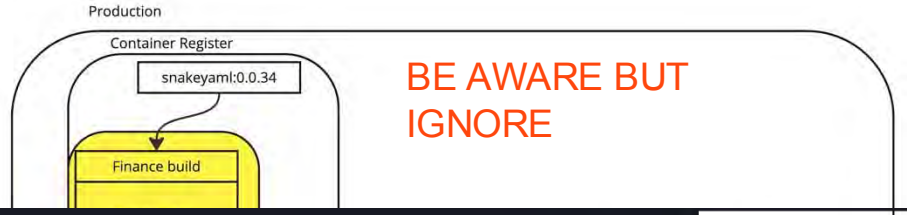
ENGINEERS



Real Case Scenario : Deduplicating Contextually Code and Libraries

FIX





BE AWARE BUT IGNORE

Where t

CVE-2022-1471 * Numbe

SCA Library pre

Issue is higher b
application is be
container that is
multiple times

PHOENIX SECURITY

- Dashboard
- Risk Explorer
- Assets
- External Dependencies
- Security
- Vulnerabilities
- Assessment Imports
- Teams
- Automation
- Integrations
- Settings

Vulnerabilities

Vulnerabilities | Findings | Group by Location

Finding Status: Open | Closed | All

Search: CVE-2022-1471 Clear All

Filters 1

Application / Environment: Select Application or Environment

Team: Finance-Fullstack × Clear all

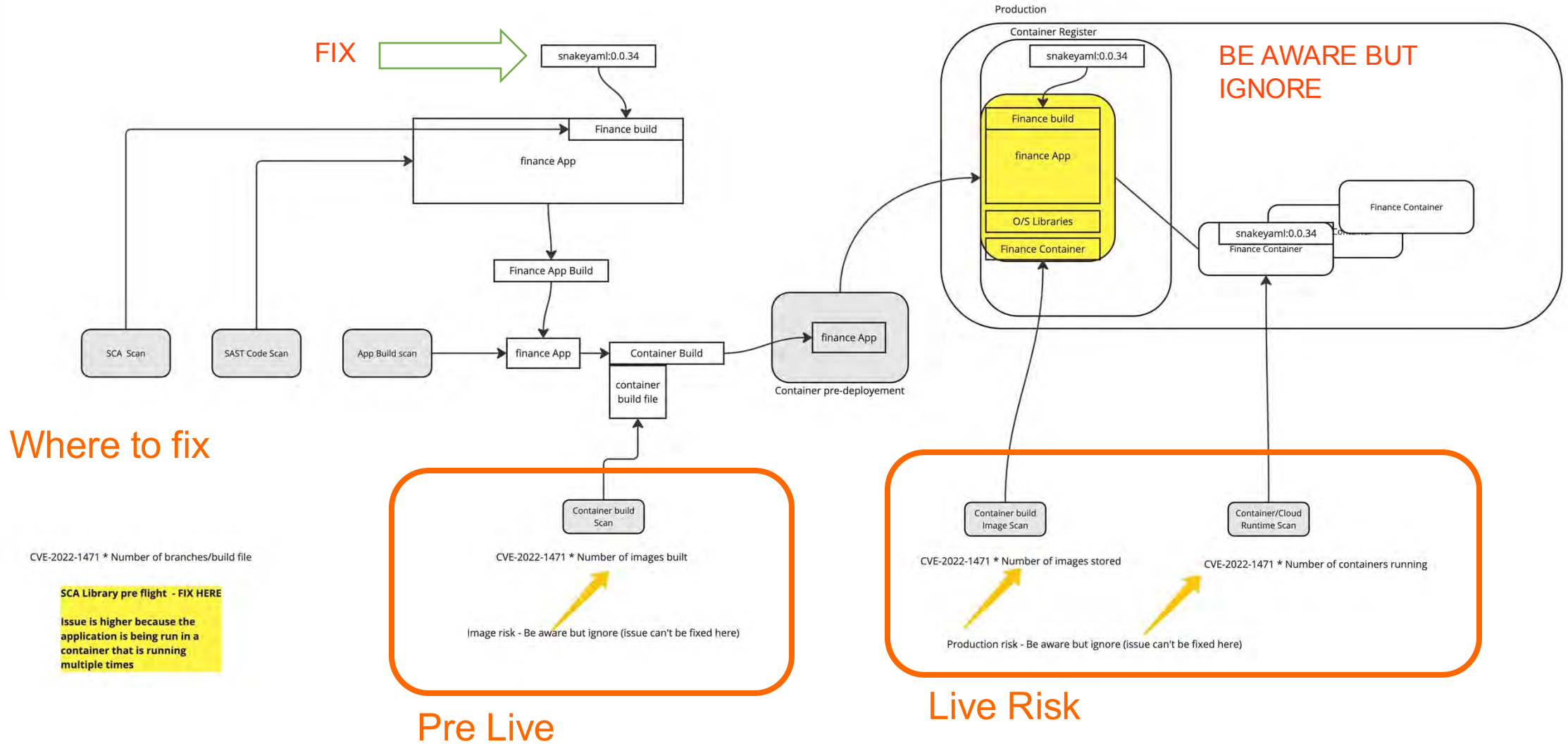
2 Results

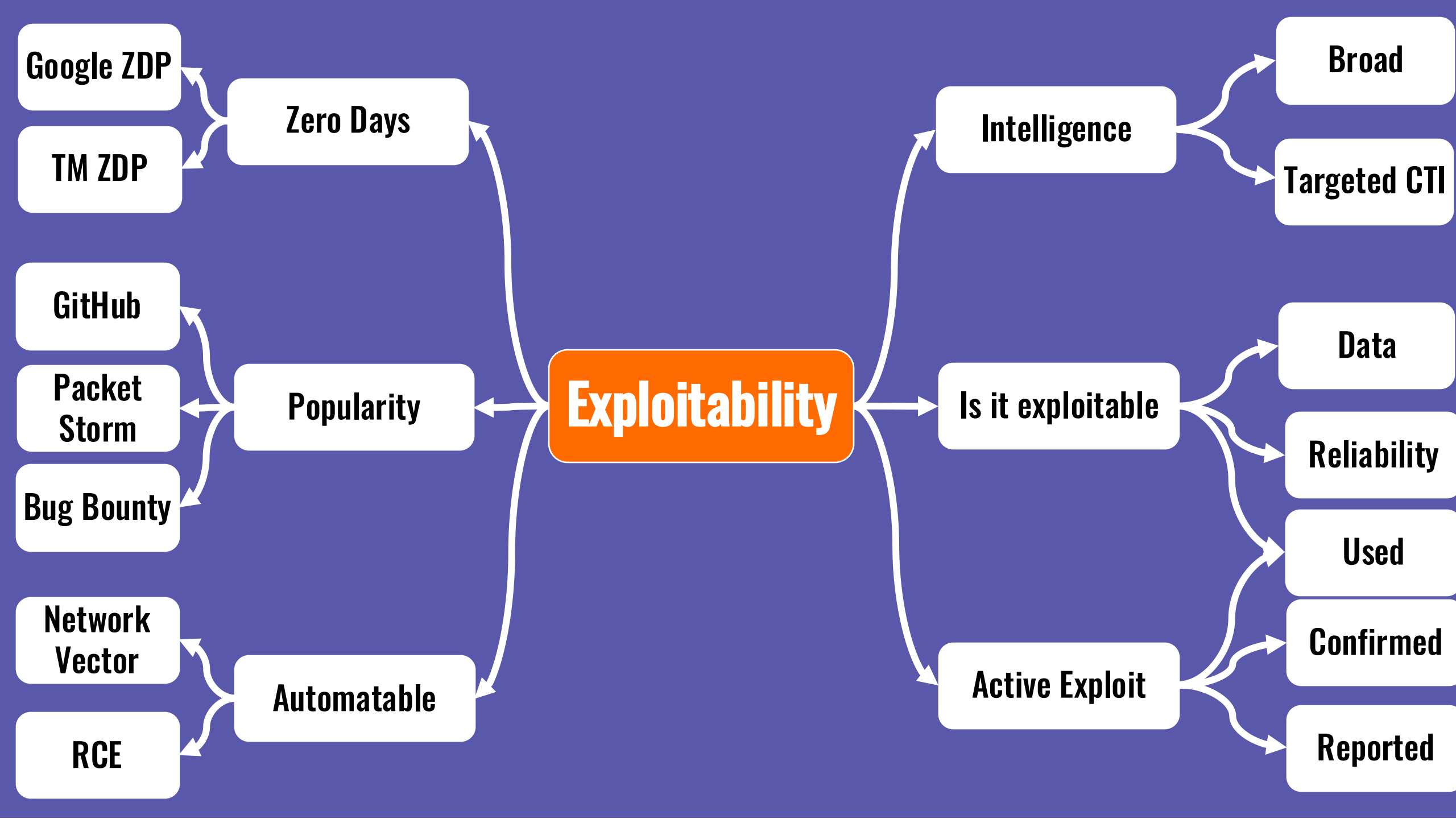
Export Findings

Risk	Asset/Location	Name	Type	CVSS / Severity	Discovery Days	Remediation Days	Exploitability (EPSS)	Risk Exception	Create Ticket / Ticket Status	Source
985	.../ container-finance:0.0.34	org.yaml:s...	Ignore	9.8	9	N/A	2.1%		-	
985	.../ finance-backend/prod	Arbitrary ...	Fix	6.6	15	N/A	2.1%			

Items per page: 100 1 – 2 of 2

One Backlog


FIX
snakeyaml:0.0.34
Finance build
finance App
Finance App Build
SCA Scan
SAST Code Scan
App Build scan
finance App
Container Build
container build file
finance App
Container pre-deployement
Production
Container Register
snakeyaml:0.0.34
Finance build
finance App
O/S Libraries
Finance Container
BE AWARE BUT IGNORE
Finance Container
snakeyaml:0.0.34
Finance Container
Where to fix
CVE-2022-1471 * Number of branches/build file
SCA Library pre flight - FIX HERE
Issue is higher because the application is being run in a container that is running multiple times
Container build Scan
CVE-2022-1471 * Number of images built
Image risk - Be aware but ignore (issue can't be fixed here)
Pre Live
Container build Image Scan
CVE-2022-1471 * Number of images stored
Container/Cloud Runtime Scan
CVE-2022-1471 * Number of containers running
Production risk - Be aware but ignore (issue can't be fixed here)
Live Risk

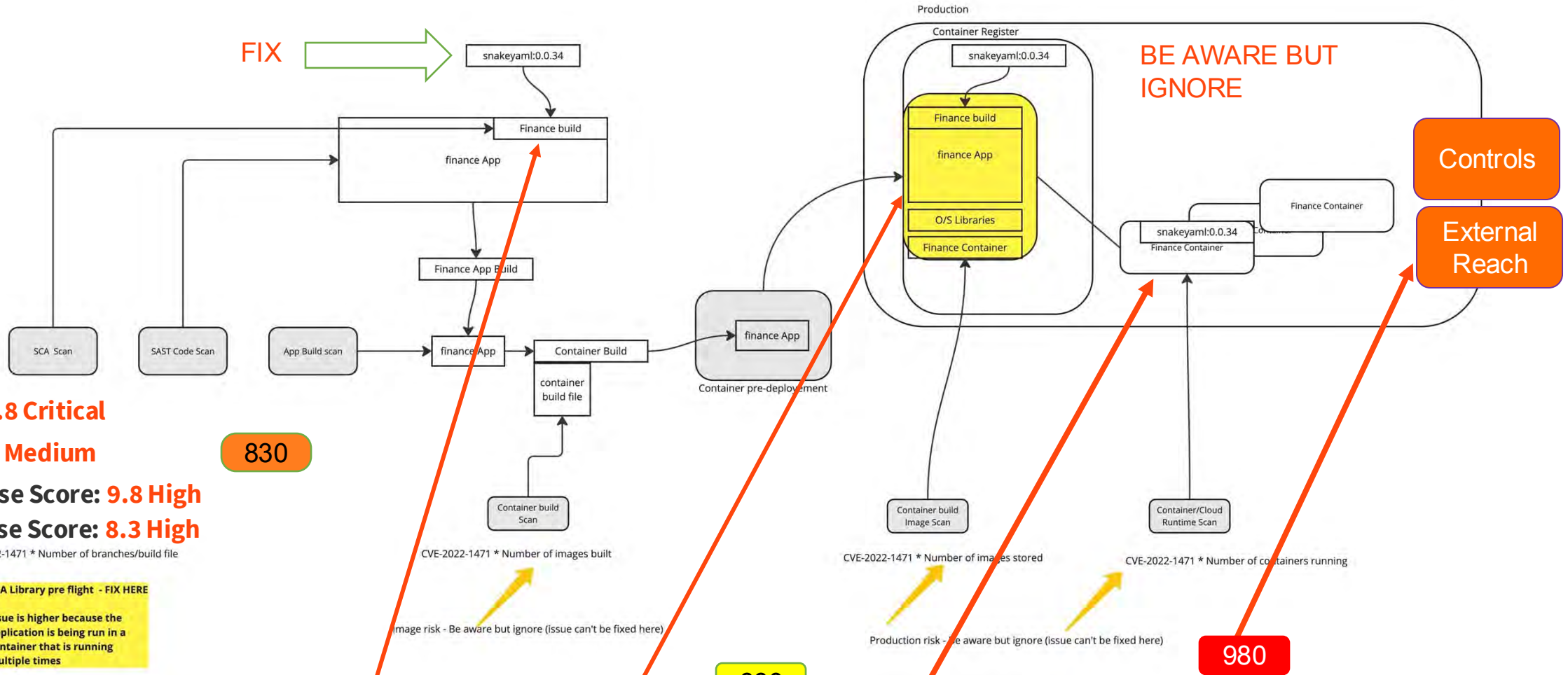

Exploitability
Zero Days
Google ZDP
TM ZDP
Popularity
GitHub
Packet Storm
Bug Bounty
Automatable
Network Vector
RCE
Intelligence
Broad
Targeted CTI
Is it exploitable
Data
Reliability
Active Exploit
Used
Confirmed
Reported

PHOENIX SECURITY | ACT ON VULNERABILIITES

Reachability Analysis of a Vulnerability

	Code Reach Reach Analysis	Runtime Reach Analysis	Container Reach Analysis	Network Reach Analysis	CTI	CTI - Exploitability
WHAT	Analyze function or library being created	Test if library is is being loaded loaded in container	Detect if the library is in a container or OS	Verify if a container's library/node is is reachable	Like EPSS identify if a vulnerability is is being exploited	Exploit evidence of a a vulnerability vulnerability
WHEN/ WERE	Code, Repo, Build	Runtime/ Build	Container Analysis, Build File	Cloud/ Operation	Everywhere	Everywhere
BENEFITS	Reduce vulnerabilities in lib/function not used	Helps identify if the code is being loaded in a container, and which container	Identify if the base image, container image or Software needs update	Helps identify if the vulnerability can be reached from Remote	Prioritization of vulnerabilities based on exploitation in wild	Prioritization of vulnerabilities based on exploit evidence
LIMITATIONS	Complex and per language	More intrusive and intensive in some instances Might require Pipeline integration	Requires container analysis	Cloud/ Network reachability analysis	Only works for network detectable Exploits	Base indicator If there is an exploit in the wild

Real Case Scenario : Deduplicating Contextually Code and Libraries



Sysdig: 9.8 Critical

Snyk: 6.6 Medium

830

CVSS - Base Score: 9.8 High

CVSS - Base Score: 8.3 High

SCA Library pre flight - FIX HERE

Issue is higher because the application is being run in a container that is running multiple times

CVSS - Base Score: 8.3 High

700

If not statically reachable -> 700

900

If network raceable 9 (loaded in a container)

660

! **EPSS - 2%** 0.021010000

Exploit available

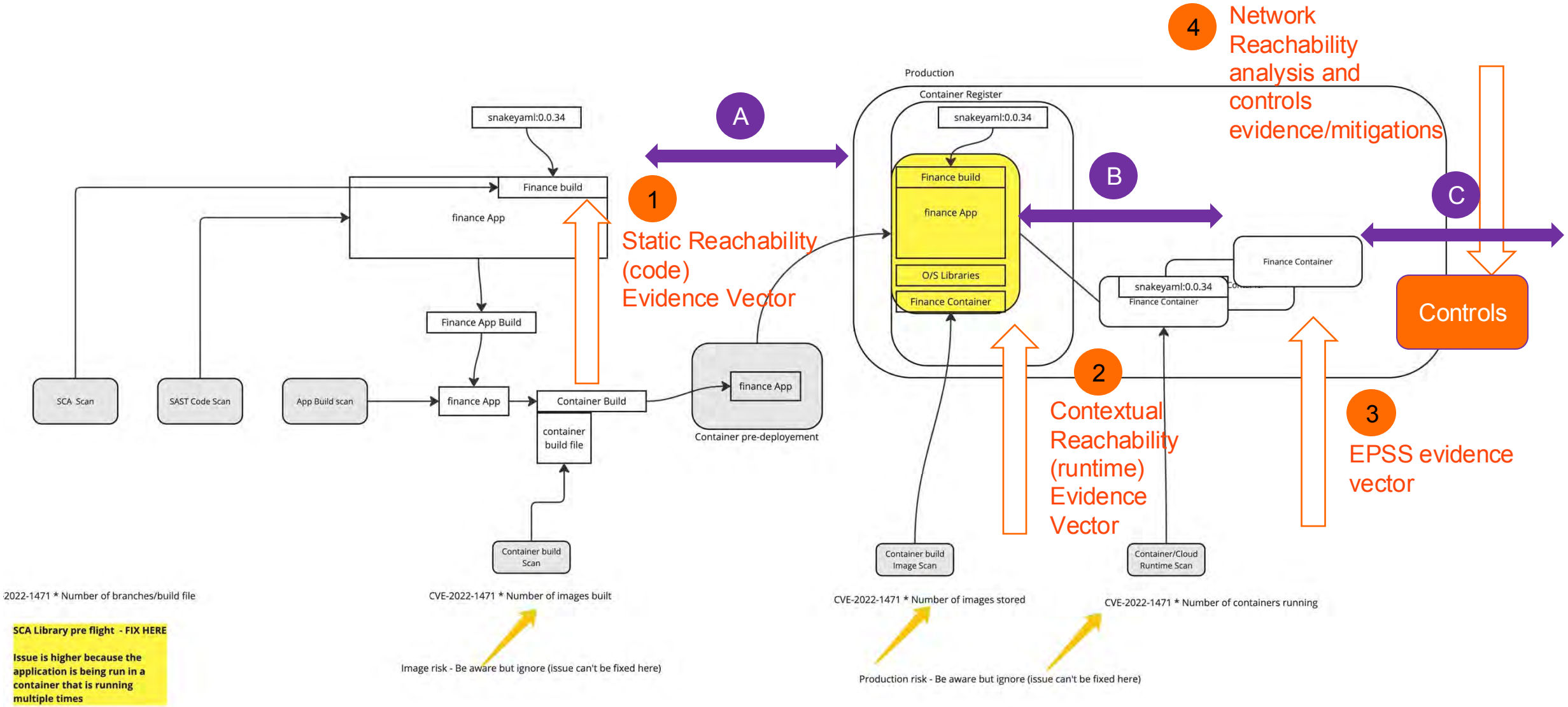
RCE

980

If externally facing

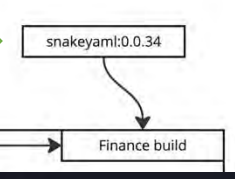
9.8 / 980

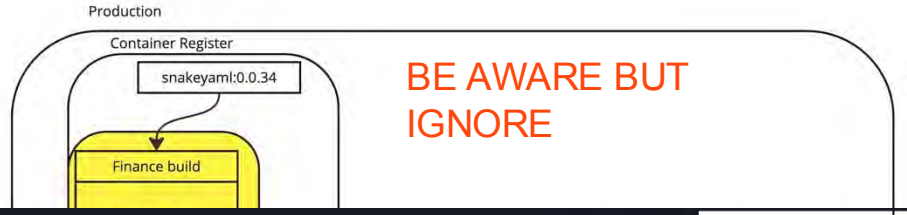
Real Case Scenario : EPSS vs Static Reachability vs Runtime/Contextual Reachability



Real Case Scenario : Deduplicating Contextually Code and Libraries

FIX





BE AWARE BUT IGNORE

Where t

CVE-2022-1471 * Numbe

SCA Library pre

Issue is higher b
application is be
container that is
multiple times

PHOENIX SECURITY

- Dashboard
- Risk Explorer
- Assets
- External Dependencies
- Security
- Vulnerabilities
- Assessment Imports
- Teams
- Automation
- Integrations
- Settings

Vulnerabilities

Vulnerabilities | Findings | Group by Location

Finding Status: Open | Closed | All

Search: CVE-2022-1471 Clear All

Filters 1

Application / Environment: Select Application or Environment

Team: Finance-Fullstack × Clear all

2 Results

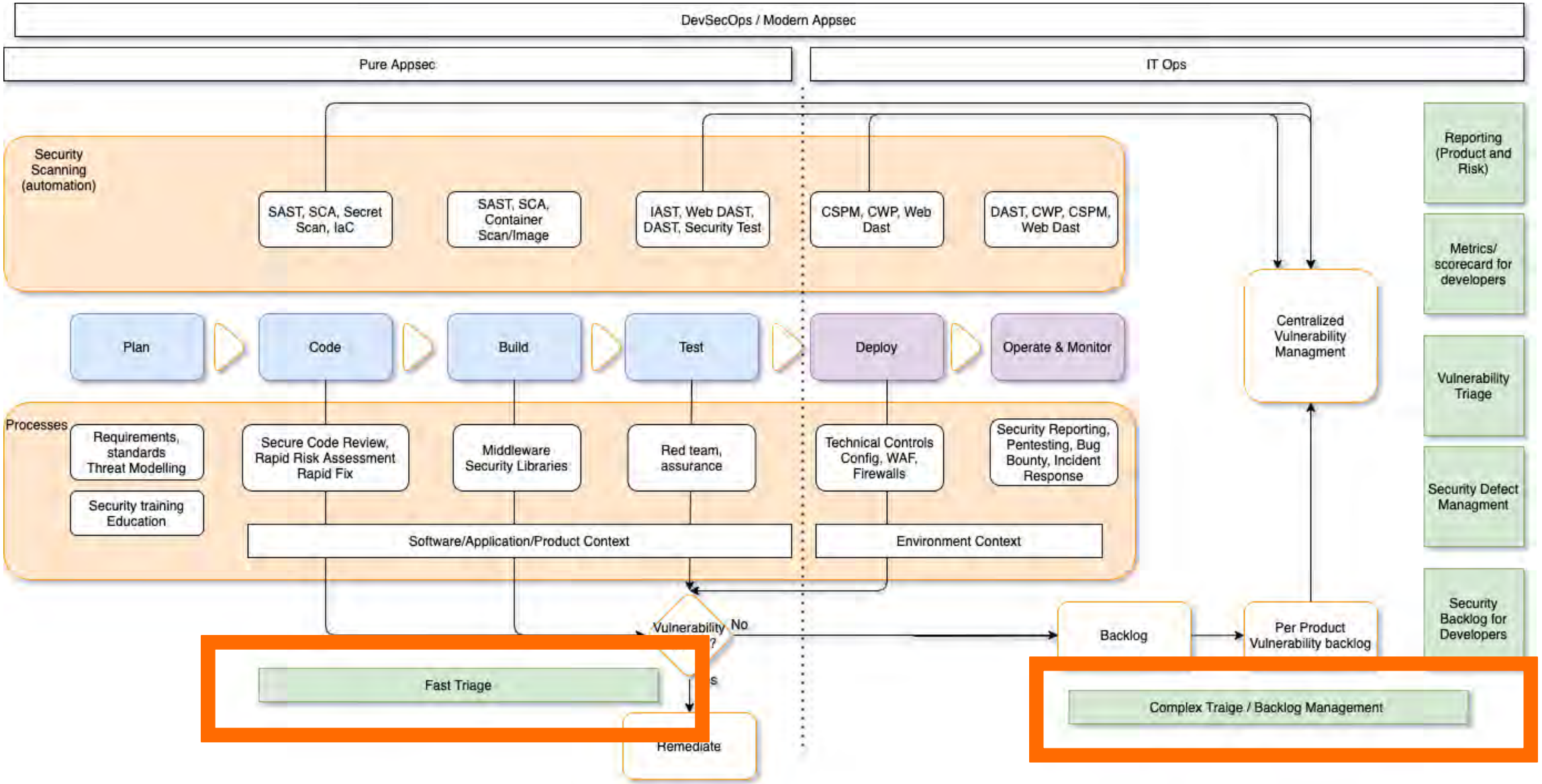
Export Findings

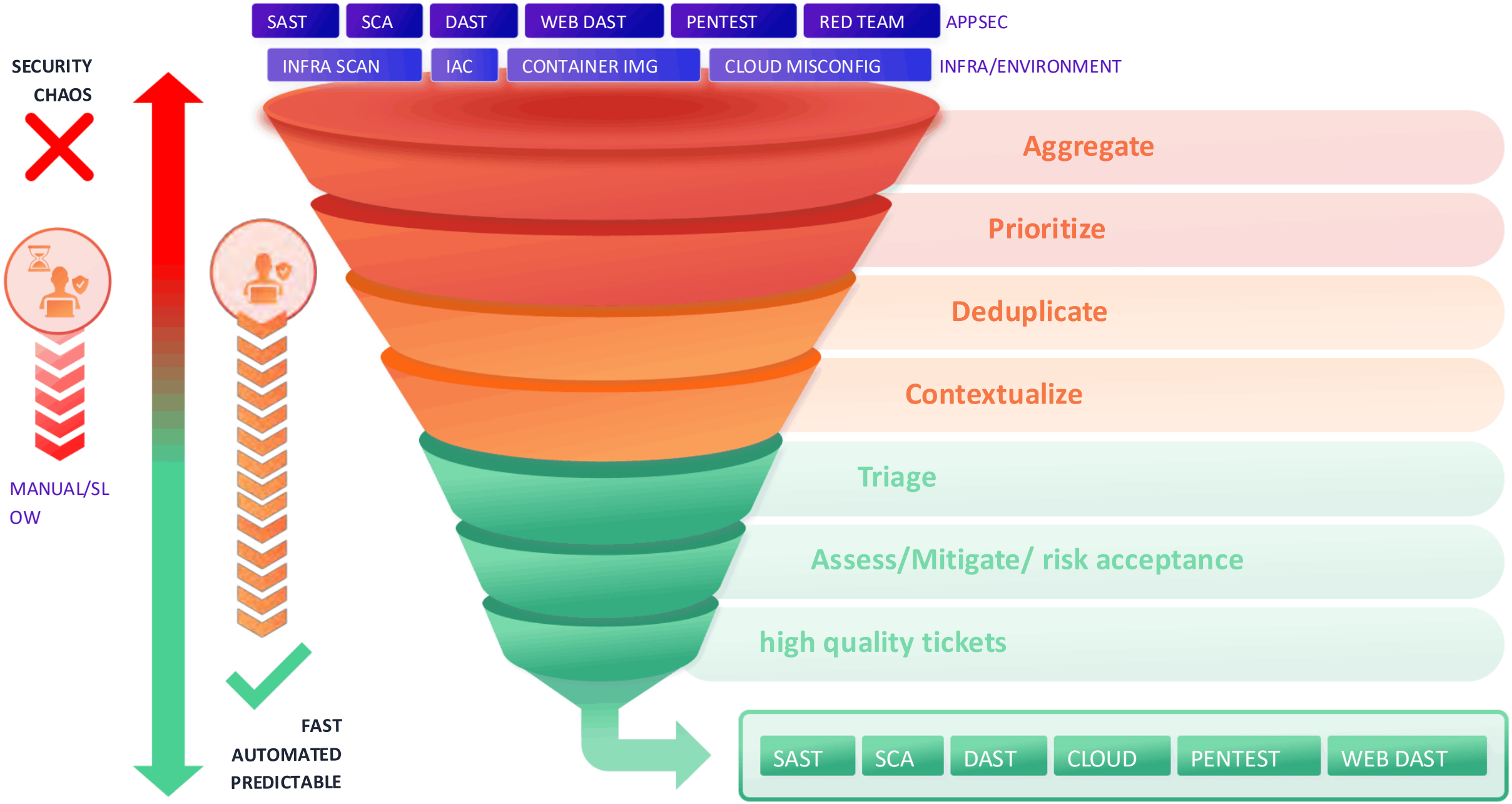
Risk	Asset/Location	Name	Type	CVSS / Severity	Discovery Days	Remediation Days	Exploitability (EPSS)	Risk Exception	Create Ticket / Ticket Status	Source
985	.../ container-finance:0.0.34	org.yaml:s...	Ignore	9.8	9	N/A	2.1%		-	
985	.../ finance-backend/prod	Arbitrary ...	Fix	6.6	15	N/A	2.1%			

Items per page: 100 1 – 2 of 2

Risk Model& Landscape

Modern security pipeline – Triage point



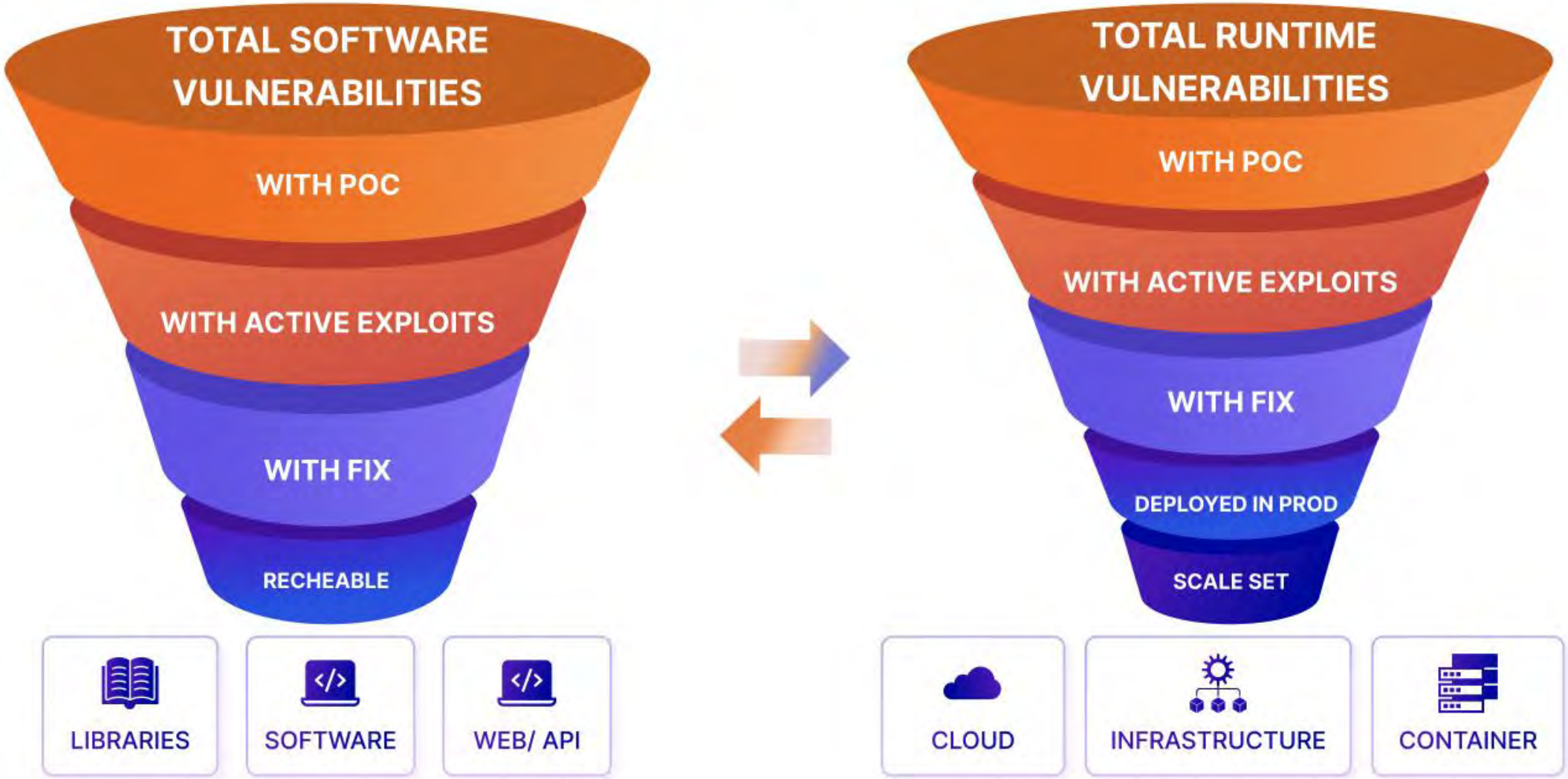


CONTEXTUALIZE PRIORITIZE | ACT ON RISK THAT MATTERS MOST

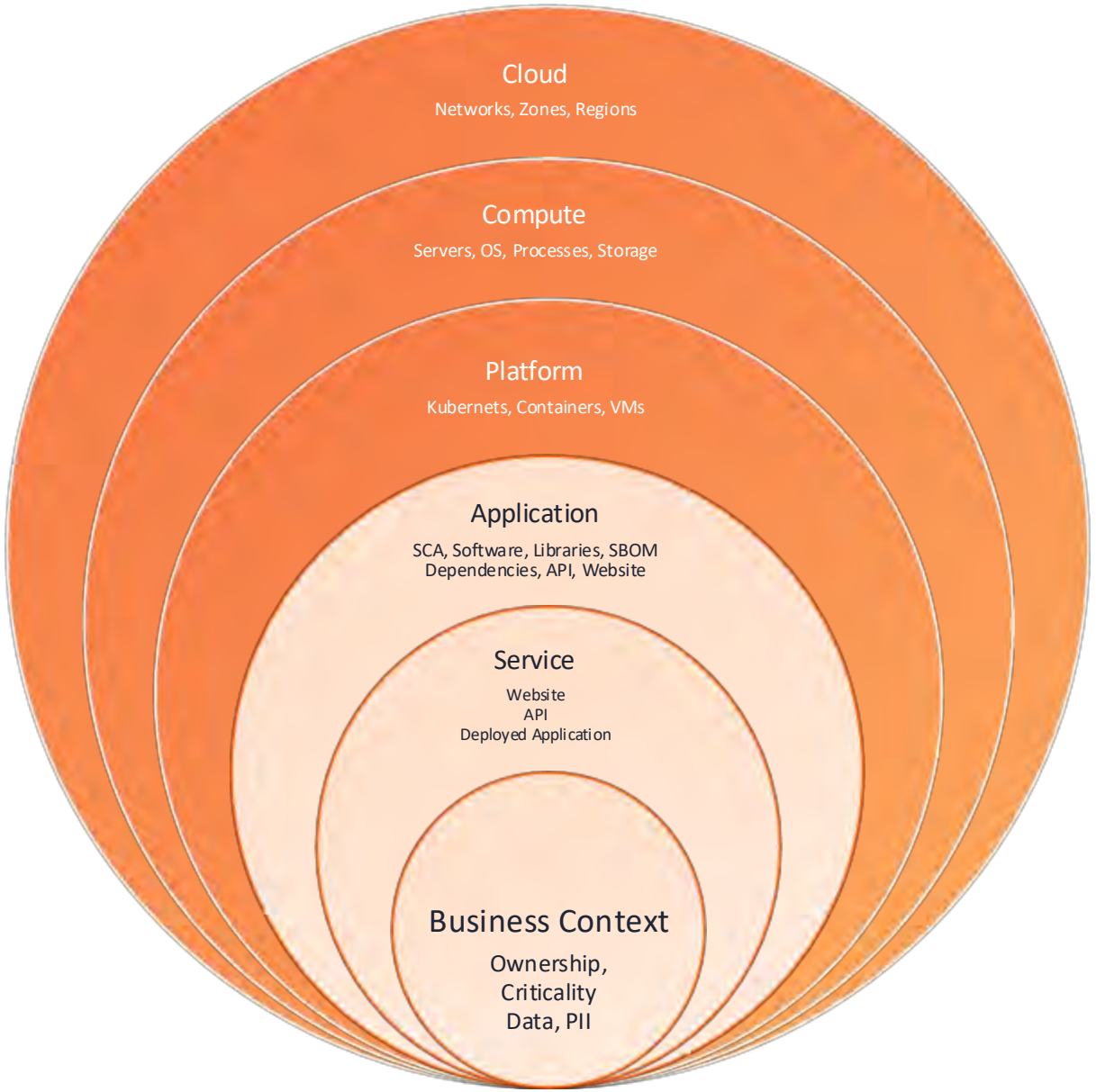
Appendix

Vulnerability is not risk

Prioritization varies depending on the deployment

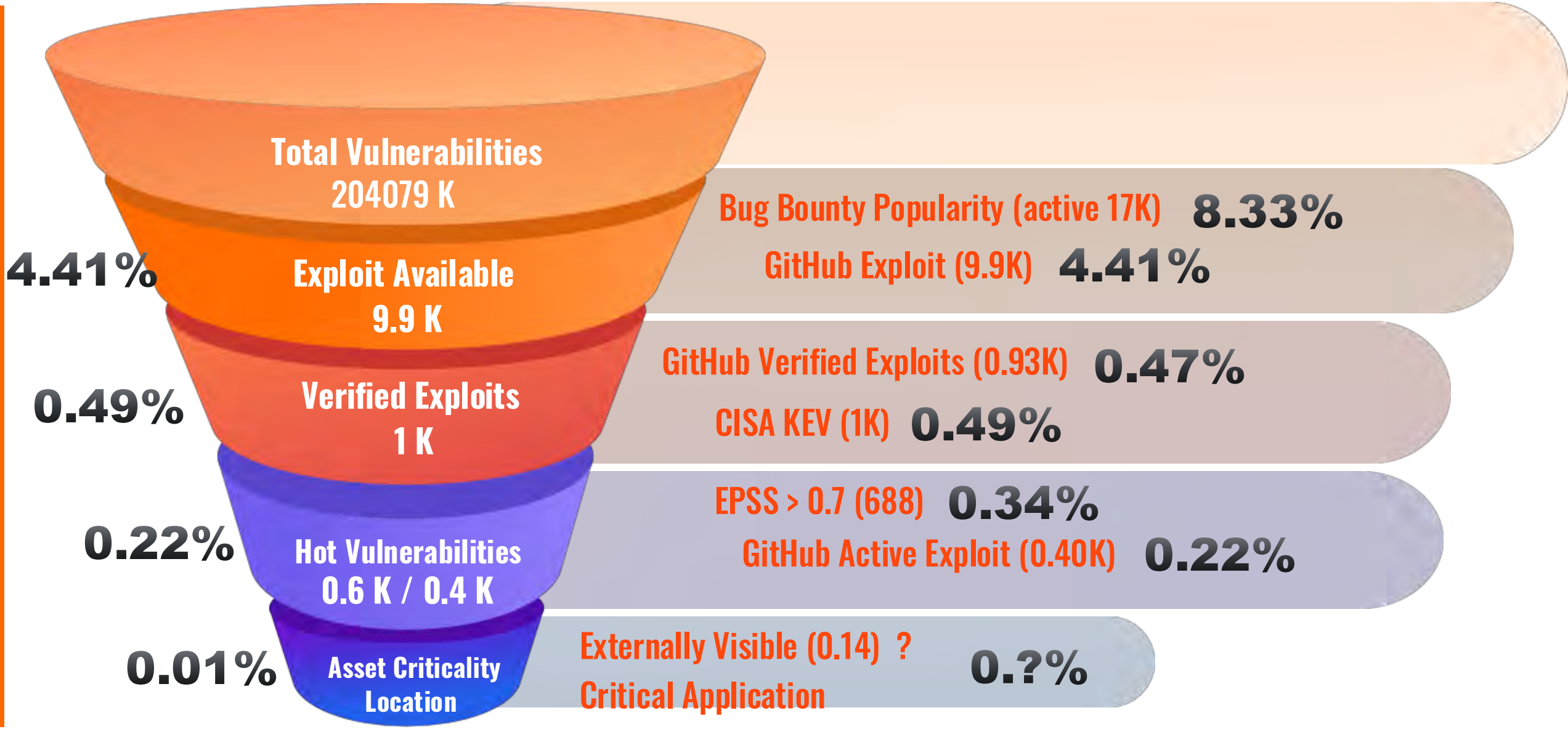


Code - Application Security / ASPM + ENVIRONMENT- Rumtime



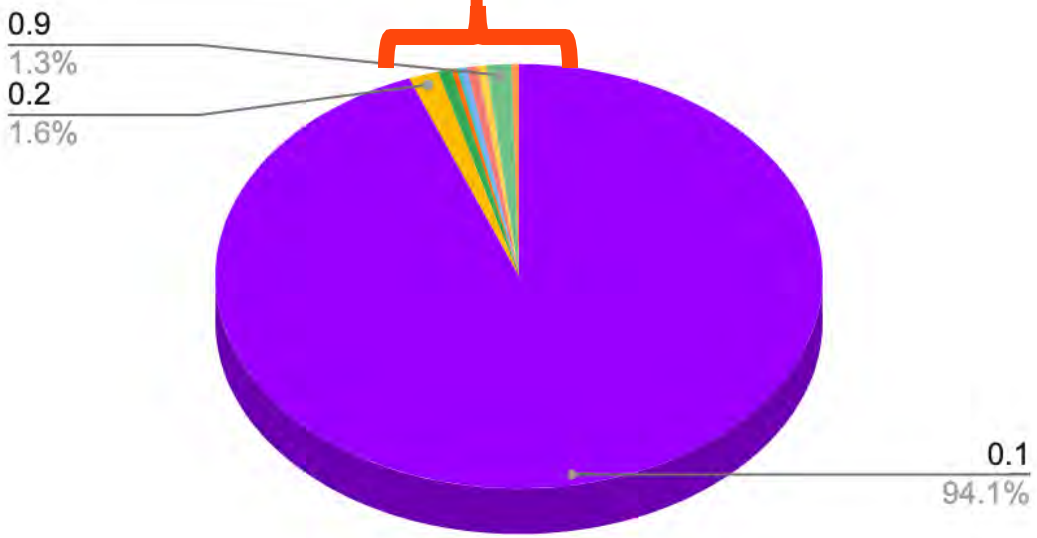
CONTEXTUALIZE PRIORITIZE | ACT ON RISK THAT MATTERS MOST

Not all the vulnerabilities require equal attention



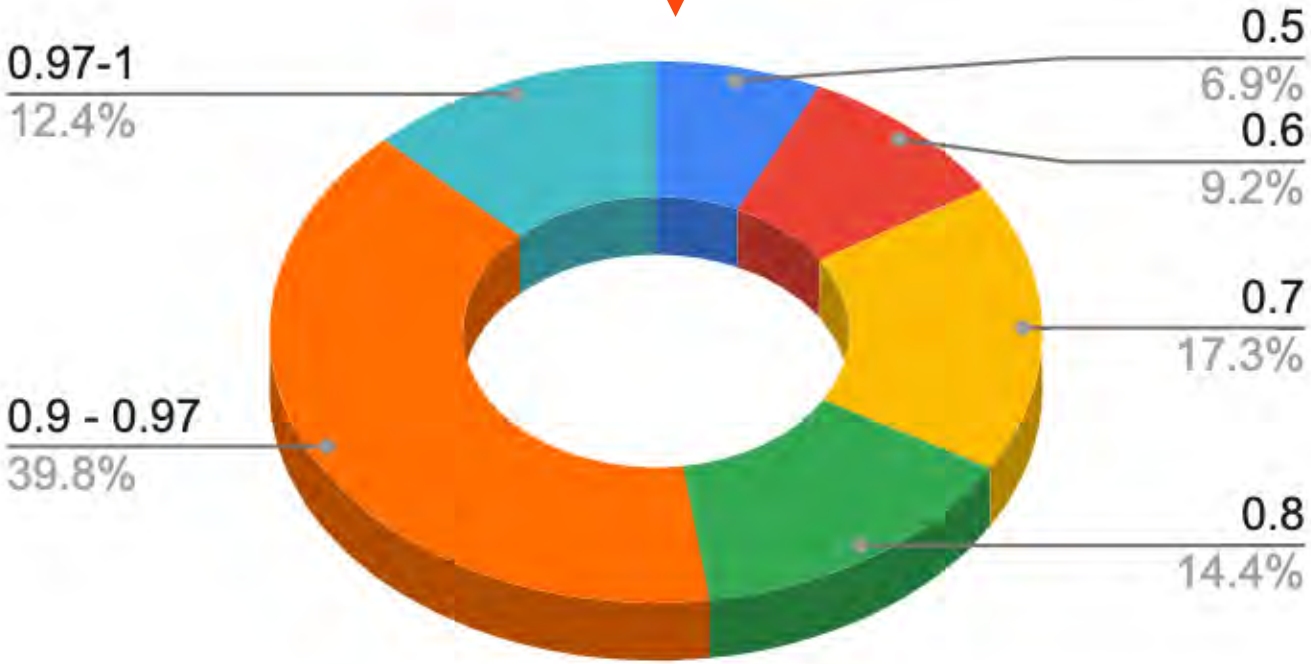
Probability of exploit: EPSS High exploitable

Values > 0.5



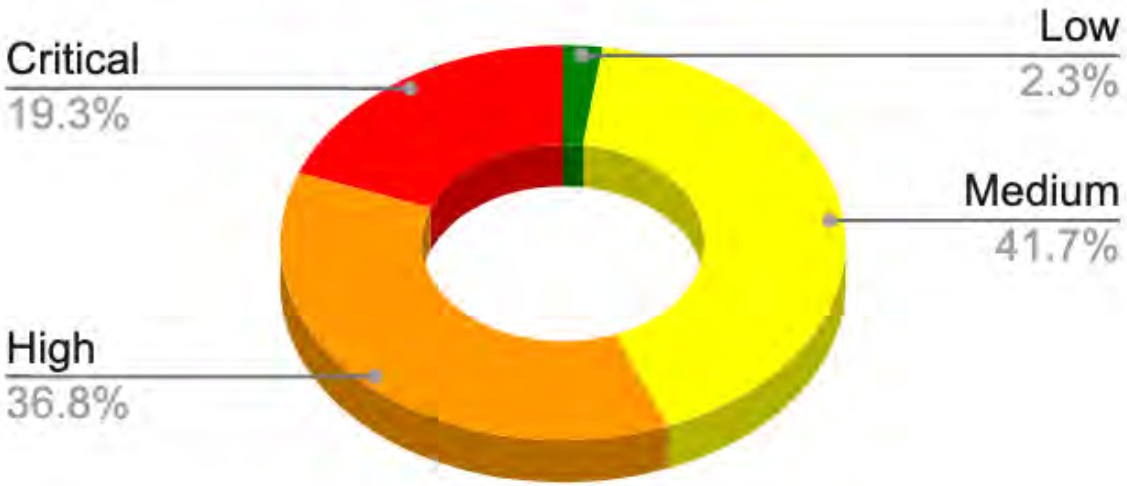
Total EPSS Values

Values > 0.5 - Breakdown

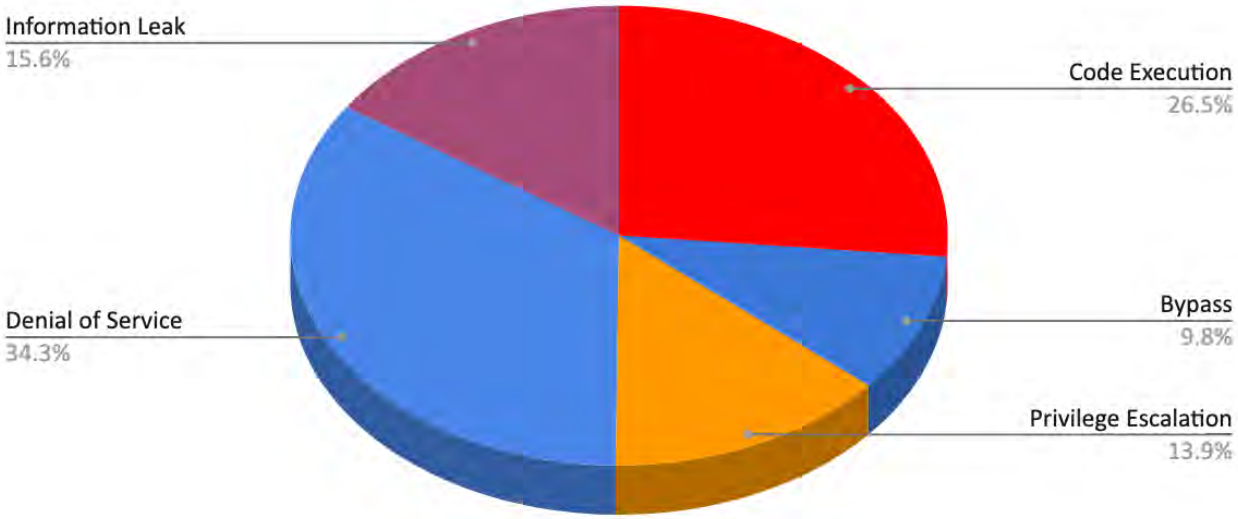


https://public.flourish.studio/visualisation/14643482/

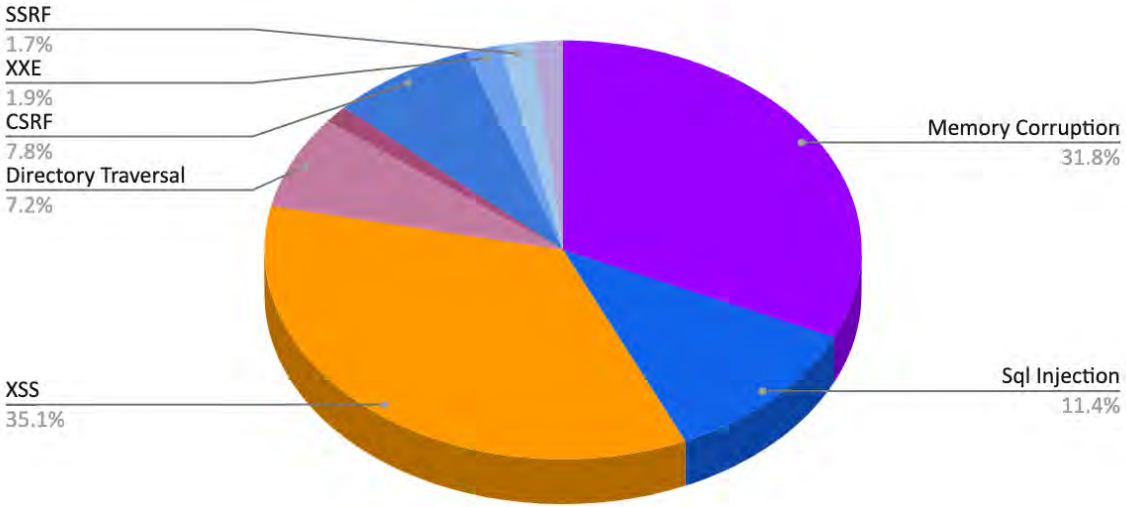
CVE Distribution



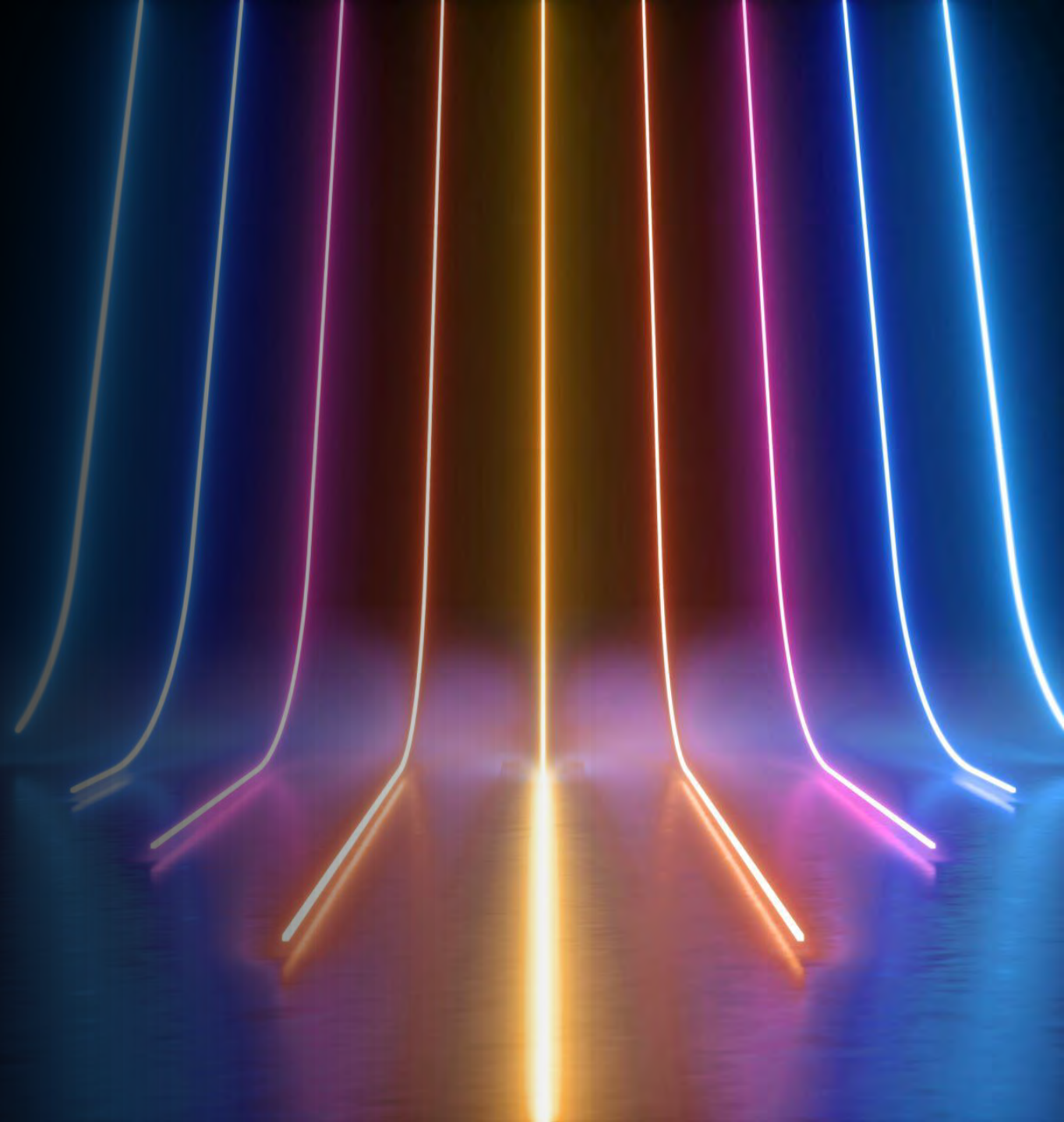
CVE Distribution by Effect



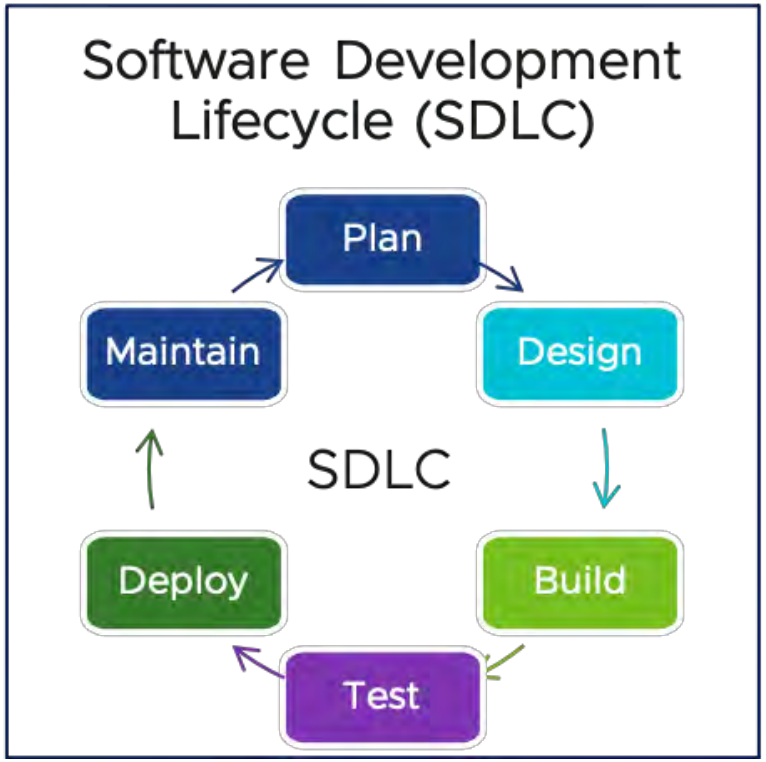
CVE Distribution by Type

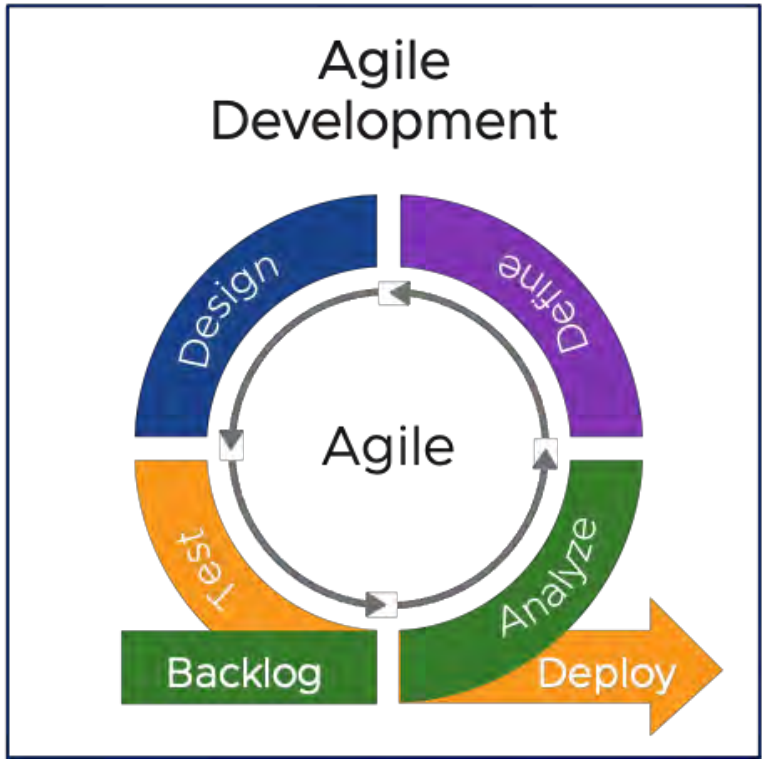


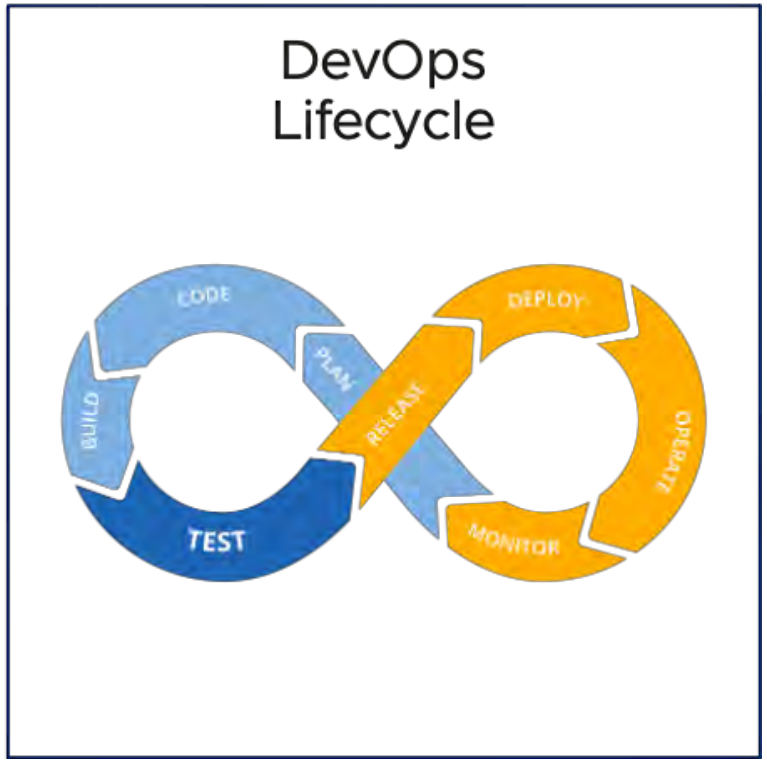
Evolution of Software, Shfit Left vs Shift Right



Evolution of Software, Shfit Left vs Shift Right







NSC42 Ltd 2019

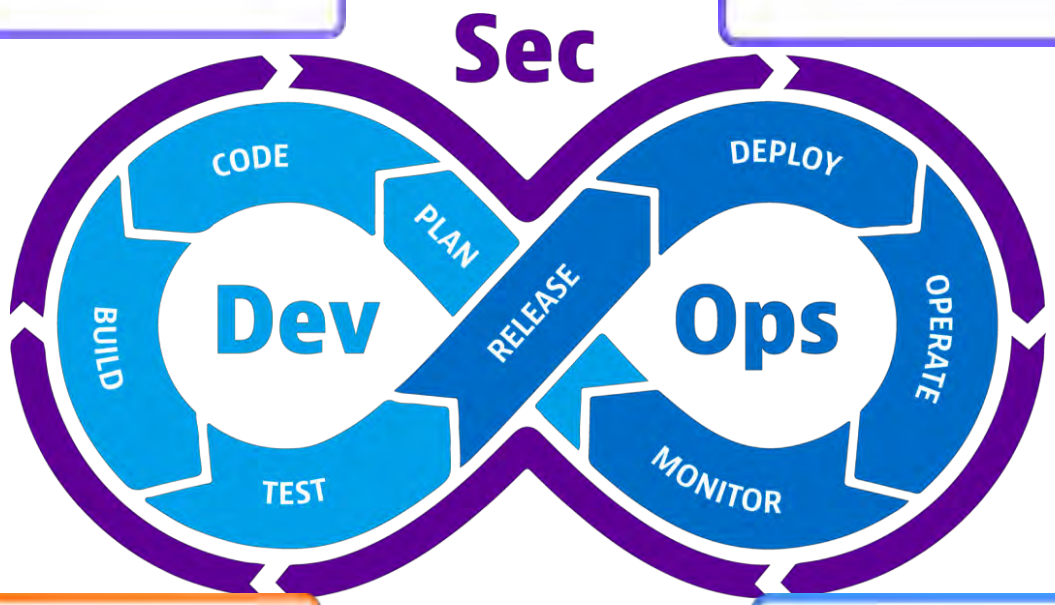
Shift Everywhere Connect business Security and Development

SHIFT DOWN (Business/SecOps)

- AGREEING RISK BASED TARGETS/
- BUSINESS IMPACT ASSESSMENT
- TRANSLATING RISK BASED PROFILES ACTIONS FOR DEVELOPERS

SHIFT UP (Business/GRC)

- RISK BASED REPORTING
- BUSINESS IMPACT ASSESSMENT
- PRIORITISING, AGGREGATING, COORDINATING RESOLUTION



SHIFT LEFT (DevOps/DevSecOps)

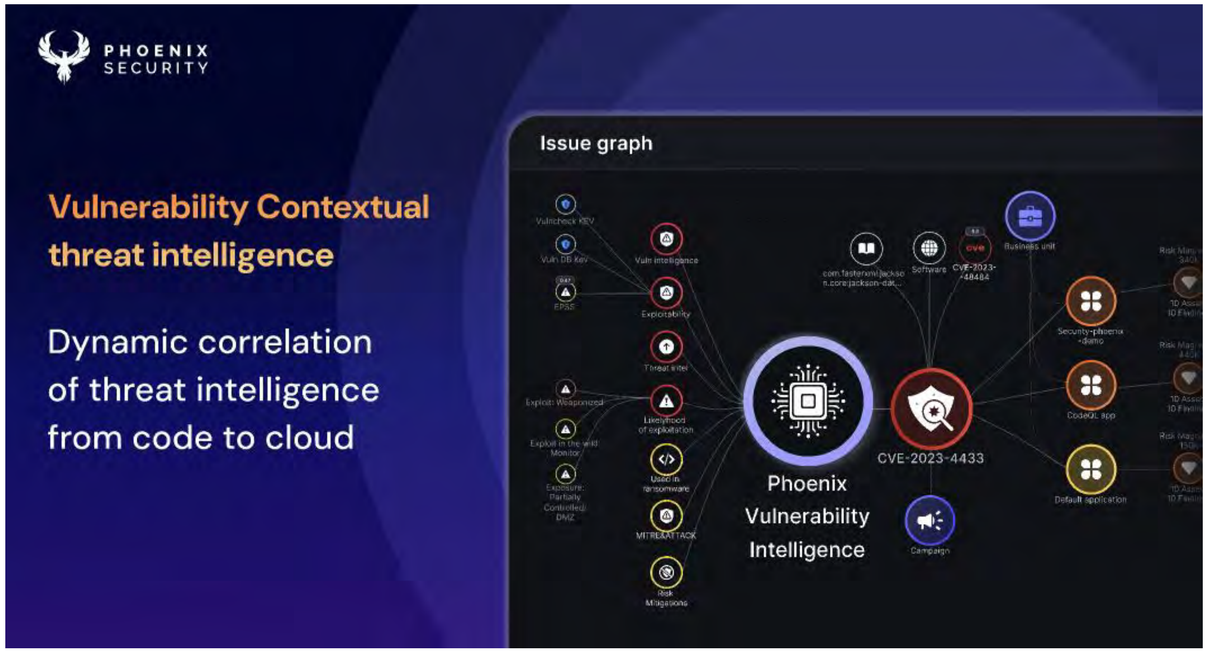
- TESTING CODE AS EARLY AS POSSIBLE
- INTEGRATING CI/CD CHECKS FOR CODE
- THREAT MODELLING, SECURITY BY DESIGN

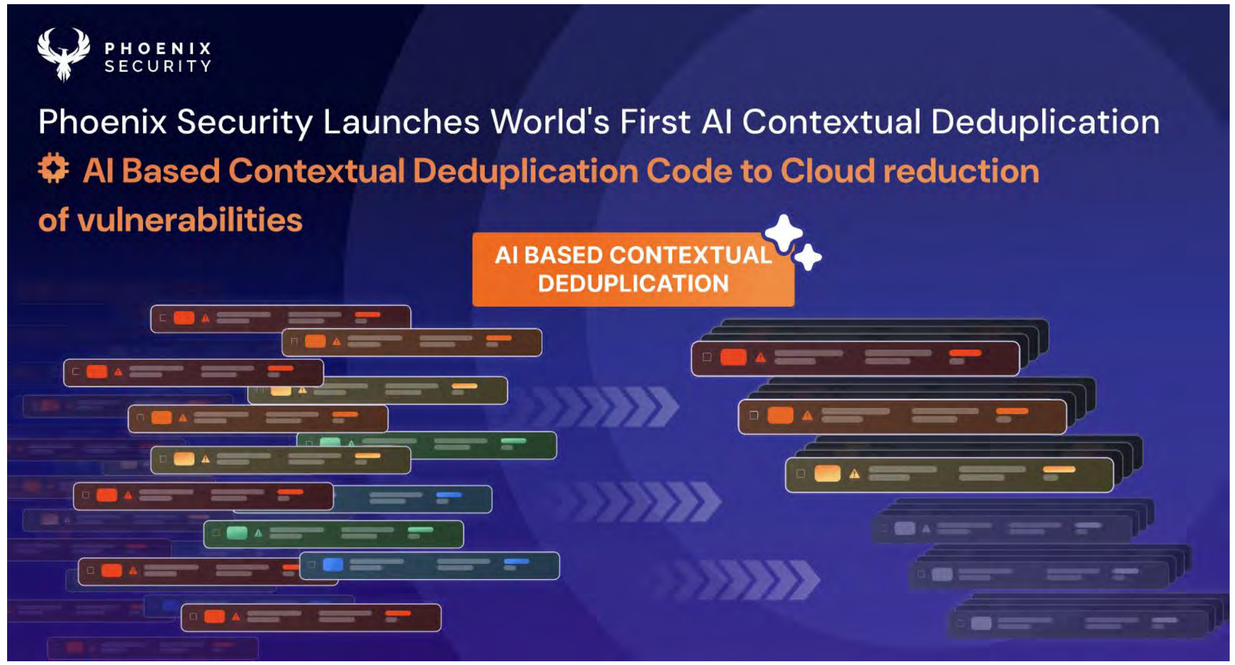
SHIFT RIGHT (Operation Security)

- O/S TESTING, IMAGE TESTING
- PEN-TESTING, BLACK/WHITE BOX TESTING
- CLOUD MISCONFIGURATION

© Phoenix Security 2023

Upcoming New Features





Copyright © 2024 Phoenix Security

Building resilient application and cloud security programs

ISC2 CHAPTER LONDON

NEW EDITION

PHOENIX SECURITY

BUILDING RESILIENT APPLICATION AND CLOUD SECURITY PROGRAMS

Author
Francesco Cipollone
CEO & Founder
Phoenix Security

Timo Pagel
DevSecOps
(DSOMM)

Kane Narrraway
Security @ CANVA

OMO OSAGIEDE
Security Architect

Chris Hughes
CEO & Founder
ACQUIA

Sam Moore
Vulnerability Management @ TMOBILE

Anuprita Patankar
Product Security @ Ecommerce Company

Chintan Gurjar
Vulnerability Management @ M&S

Copyright © 2024 Phoenix Security

New Book on metrics that matters